Tahweel Tech Solutions

Department: IT-Cybersecurity | Owner: Noura Al-Shehri | Classification: Internal

Information Security Policy - NCA Essential Cybersecurity Controls (ECC-1:2018)

Purpose and Scope

This policy implements the Saudi National Cybersecurity Authority's Essential Cybersecurity Controls (ECC-1:2018) across all Tahweel Tech Solutions systems, including the Madar internal file-sharing and AI document retrieval platform hosted on Microsoft Azure.

Identity and Access Management

- Multi-Factor Authentication (MFA) is mandatory for all users accessing Madar, email, and any system containing internal company data, with no exceptions for administrative accounts.
- Access follows the principle of least privilege: users and the AI retrieval layer may only read documents belonging to their assigned department group.
- Passwords must be a minimum of 12 characters, rotated every 90 days, and may not be reused across the last 10 password cycles.
- Privileged (administrator) accounts are reviewed quarterly and require separate credentials from standard user accounts.

Data Protection Standards

- Data at rest: encrypted using AES-256, applied to the Nextcloud data volume, the PostgreSQL database, and all backup archives.
- Data in transit: all connections must use TLS 1.3; TLS 1.2 is permitted only as a fallback for legacy client compatibility and is scheduled for deprecation by Q1 2027.
- Encryption keys are rotated annually and stored separately from the data they protect.

Network Security

Production infrastructure sits behind an Azure Network Security Group (NSG) that permits inbound traffic only on ports 443 (HTTPS) and 22 (SSH, restricted to an allow-list of administrator IP addresses). All other inbound ports are denied by default.

Audit Logging

All access to documents through Nextcloud and the AI retrieval service is logged, including user identity, timestamp, department context, and the specific documents or chunks returned. Audit logs are retained for a minimum of 12 months and reviewed monthly by the Cybersecurity team for anomalous access patterns.

Incident Response

- Suspected security incidents must be reported to the Cybersecurity team within 1 hour of detection.
- Critical incidents (data breach, ransomware, unauthorized privileged access) trigger the Incident Response Plan and must be reported to the NCA within 24 hours where required by law.
- A post-incident review is conducted within 5 working days of resolution.